Bug Bounty Research Tips Part 2

Educational Bug Bounty Series • Authorized Security Research Only

■ Bug Bounty Research Tips — Part 2

Contributed by Cyber_Spy.404 | Educational Bug Bounty Series

Scope: *Apply reconnaissance and testing techniques only to assets permitted by a bug bounty program. Avoid secret extraction, account takeover, destructive tests, and high-volume scanning.*

■ Executive Summary

The supplied *tips twitter 2.pdf* collects short research notes about XSS filtering, Adobe Experience Manager JSON routes, file-upload extension policy, SQL injection indicators, phpMyAdmin behavior, SVN exposure, and parameter-name injection. The notes are exploratory observations, not proof that the techniques work on every target.

■ Core Testing Methodology

1. Read the program scope and rate limits before reconnaissance.
2. Inventory known, in-scope URLs and identify the technology only when evidence supports it.
3. For AEM, review documented JSON endpoints and expected access behavior without enumerating unrelated content.
4. Review upload policy using harmless files in a controlled environment.
5. Check SQL injection through code review or approved non-destructive test methods.
6. Verify admin/setup interfaces are properly restricted and interpret redirects/status codes in context.
7. Review exposed SVN metadata without downloading or extracting repository contents.
8. Test parameter parsing with harmless markers in a lab.
9. Document reproducible evidence, impact, and uncertainty.

■ High-Value Bug Bounty Tips & Edge Cases

- **XSS filters:** Location concatenation and filtering can produce context-specific behavior. Use a harmless marker and focus on contextual output encoding rather than payload collections.
- **AEM JSON routes:** The source lists alternate `.infinity`/JSON-style routes. Validate only expected public endpoints and do not scrape private content.
- **Upload extensions:** The source labels server-side script extensions as potentially executable and HTML/SVG-like formats as potential XSS. Enforce a strict allowlist and safe serving.
- **SQL injection:** The source describes a sitemap endpoint and time-delay testing. Do not use delay payloads against production unless explicitly permitted; prefer staging or safe validation.
- **phpMyAdmin:** Redirect/status observations alone do not prove setup exposure or authentication bypass. Verify expected access with a controlled environment.
- **SVN:** Exposed metadata can disclose source history; do not use extraction tools on third-party repositories.
- **Parameter-name injection:** Treat this as a validation and query-construction review category.
- **Source limitation:** These are short social-media-style notes, not a validated methodology or universal bypass list.

■■ Educational Checklists & Safe Examples

```
Target: [Your-Domain]
Scope confirmed: [Yes/No]
Technology evidence: [Observed Indicator]
Test category: [XSS / AEM / Upload / SQLi / Admin Interface / SVN]
Method: [Code Review / Staging / Approved Non-Destructive Test]
Result: [Confirmed / Not Reproduced / Inconclusive]
Evidence: [Redacted]
```

- [ ] Scope and rate limits checked.
- [ ] Only harmless fixtures used.
- [ ] No source repository was extracted.
- [ ] No high-volume or delay-based tests were run without approval.
- [ ] Findings distinguish evidence from hypothesis.

■■ Mitigation & Remediation

Use context-aware output encoding, validate routes and parameters, restrict upload types and execution, parameterize SQL queries, protect setup/admin interfaces, block version-control metadata, and log/review anomalous requests.

■ Source Notes

Based on the supplied three-page *tips twitter 2.pdf*. Page 1 covers XSS filter behavior and AEM JSON route variations. Page 2 lists file extensions, a SQLi/time-delay example, and phpMyAdmin setup behavior. Page 3 includes SVN metadata and parameter-name injection notes. High-risk payloads and repository-dumping instructions are omitted.

Educational use only. Follow program scope and rate limits.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.